

Network Security Standard

Technical Network Controls and Requirements

CONFIDENTIAL

Document ID

MIG-POL-004

Effective Date

December 1, 2025

Approved By

CISO and CTO

Review Cycle

Semi-Annual

Version

4.0

Document Owner

VP of Network Engineering

Regulatory Alignment

PCI DSS 4.0, NIST CSF 2.0, CIS Benchmarks

Document Control

Revision History

Version	Date	Author	Changes	Approved By
4.0	Dec 2025	J. Park, VP NetEng	Major revision - IoT blocking mandate	A. Nakamura
3.5	Jun 2025	J. Park	Added WAF bypass prohibition	A. Nakamura
3.2	Dec 2024	M. Brown	Updated segmentation requirements for cloudJ. Park	
3.0	Jun 2024	M. Brown	Added DNS security requirements	J. Park
2.5	Dec 2023	S. Kim	Legacy protocol prohibition	M. Brown

Approval Signatures

Role	Name	Signature	Date
Document Owner	VP of Network Engineering	_____	December 1, 2025
CISO	CISO and CTO	_____	December 1, 2025
General Counsel	Legal Department	_____	December 1, 2025

Distribution

This document is distributed to all employees via the corporate policy portal, Information Security, IT Operations, Compliance and Risk Management, Legal, Internal Audit, and the Executive Leadership Team.

Related Documents

Document ID	Title	Relationship
MIG-POL-001	Acceptable Use Policy	Sibling
MIG-POL-002	Information Security Policy	Sibling
MIG-POL-003	Data Sharing and Transfer Policy	Sibling
MIG-POL-004	Network Security Standard	Technical Standard
MIG-POL-005	Vendor Access Policy	Sibling
MIG-STD-010	Encryption Standards	Technical Standard
MIG-STD-012	IAM Standard	Technical Standard

Table of Contents

- 1. Purpose and Scope**
- 2. Web Application Firewall Requirements**
- 3. Environment Segmentation**
- 4. IoT and OT Device Security**
- 5. DNS Security**
- 6. Firewall and Security Group Standards**
 - 6.1 Prohibited Configurations
 - 6.2 Legacy Protocol Restrictions
- 7. Traffic Forwarding and Cloud Security Gateway**
- 8. Cloud Storage Security**
- 9. Configuration Change Management**

1. Purpose and Scope

This standard defines the technical network security requirements for all Meridian Insurance Group environments, including on-premises data centers, cloud infrastructure (AWS, Azure), branch offices, partner connections, and remote access pathways. All network configurations, security groups, firewall rules, routing tables, and access control lists must comply with this standard. Non-compliant configurations must be remediated within 24 hours of detection for Critical findings and 72 hours for High findings.

2. Web Application Firewall Requirements

CRITICAL REQUIREMENT: MIG-POL-004-WAF01

All inbound traffic to production web applications must pass through the Web Application Firewall (WAF) prior to reaching any application component. No security group, network ACL, or load balancer listener shall permit direct public internet access (0.0.0.0/0) to any production application resource. This includes application load balancers, API gateways, and container ingress controllers. **Temporary exceptions for vendor integrations, debugging, or testing are not permitted.** All vendor access must route through the WAF or through Zscaler Private Access (ZPA). Violations of this requirement are classified as Critical severity and require immediate remediation.

The WAF must be configured with OWASP Core Rule Set (CRS) 4.0 or later. Custom rules for insurance-specific attack patterns (policy number enumeration, claims ID brute force) must be maintained by the Application Security team. WAF logs must be forwarded to the SIEM within 60 seconds.

3. Environment Segmentation

POLICY MANDATE: MIG-POL-004-SEG01

Production, staging, development, and sandbox environments must be **fully network-segmented**. VPC peering connections, transit gateway attachments, PrivateLink endpoints, or any other network construct that creates a direct packet path between production VPCs/VNets and non-production VPCs/VNets is **prohibited**. Data movement between environments must occur through approved CI/CD pipelines with PII data masking applied to any production data replicated to lower environments.

4. IoT and OT Device Security

Internet of Things (IoT) devices, operational technology (OT) systems, building management systems, and any non-standard network-connected devices present elevated risk due to limited patching, default credentials, and non-standard protocols:

CRITICAL REQUIREMENT: MIG-POL-004-IOT01

All IoT and OT devices must be placed on a dedicated, isolated VLAN (IoT-VLAN) with **no routing to corporate data VLANs**. IoT devices are prohibited from initiating outbound connections to the public internet. Any IoT device detected communicating with external IP addresses **must be automatically blocked within 5 minutes** and an alert generated to the SOC. **Monitoring-only mode is not acceptable** for IoT external communication controls; **active blocking is mandatory**. Firmware updates must be delivered through an internal update proxy server, not via direct internet download. Unapproved IoT devices must be quarantined at the network layer upon detection.

5. DNS Security

All DNS queries from corporate networks must resolve through the approved internal DNS infrastructure with DNS-layer threat protection. Direct DNS to external resolvers (8.8.8.8, 1.1.1.1, etc.) must be blocked at the firewall level.

- Queries to known malicious domains: automatically blocked
- Newly registered domains (less than 30 days old): automatically blocked
- High-entropy domain names (entropy score > 80): blocked with SOC alert
- DNS over HTTPS (DoH) and DNS over TLS (DoT) to non-corporate resolvers: blocked
- DNS tunneling detection: enabled with automatic blocking

6. Firewall and Security Group Standards

6.1 Prohibited Configurations

All firewall rules and cloud security groups must follow the principle of least privilege. The following configurations are explicitly prohibited and will be flagged as non-compliant by automated scanning:

- Inbound rules allowing 0.0.0.0/0 on any port to any production resource
- Outbound rules allowing all traffic (0.0.0.0/0 all ports) from production
- Security groups with no description, no owner tag, or no expiration tag
- Rules older than 180 days without a documented business justification in ServiceNow
- Any rule permitting SSH (22) or RDP (3389) from 0.0.0.0/0
- Cross-environment rules (production to dev, staging to production)

6.2 Legacy Protocol Restrictions

POLICY MANDATE: MIG-POL-004-LP01

Legacy unencrypted protocols are prohibited on all network segments: **Telnet (port 23), FTP (port 21), HTTP (port 80 for application traffic), SNMP v1/v2c, and rsh/rlogin**. SSH (port 22) is the only permitted remote administration protocol. SFTP or SCP must replace FTP for all file transfers. HTTPS must replace HTTP for all web traffic. SNMP v3 with authentication and encryption must replace SNMP v1/v2c.

7. Traffic Forwarding and Cloud Security Gateway

POLICY MANDATE: MIG-POL-004-FWD01

All internet-bound traffic from corporate networks must be forwarded through the approved cloud security gateway (Zscaler Internet Access) for inspection, URL filtering, DLP enforcement, and threat protection. Traffic forwarding must use encrypted tunnels (GRE or IPSec) between all corporate locations and the cloud security gateway. Local internet breakout is not permitted at any branch location.

Private/internal traffic between corporate subnets may bypass the cloud gateway but must still traverse internal firewalls with full logging enabled.

8. Cloud Storage Security

All S3 buckets and cloud storage resources in production accounts must meet the following baseline security requirements:

POLICY MANDATE: MIG-POL-004-S3-01

All S3 buckets in production AWS accounts must have: (a) server-side encryption enabled using AWS KMS (SSE-KMS) for Tier 1 and Tier 2 data, (b) S3 Block Public Access enabled on all four settings (BlockPublicAcls, IgnorePublicAcls, BlockPublicPolicy, RestrictPublicBuckets), (c) versioning enabled, (d) access logging enabled with logs forwarded to the centralized log bucket, and (e) lifecycle policies configured for cost optimization. Buckets that fail any of these controls must be remediated within 24 hours of detection.

9. Configuration Change Management

All network configuration changes (firewall rules, security groups, routing tables, VPN configurations, DNS records) must follow the Change Advisory Board (CAB) process. Emergency changes require post-hoc CAB review within 48 hours. All changes must be logged in the Configuration Management Database (CMDB) and trigger automated compliance checks within 15 minutes of implementation.

Appendix A: Definitions and Acronyms

Term	Definition
AES	Advanced Encryption Standard - symmetric block cipher
CASB	Cloud Access Security Broker
CISO	Chief Information Security Officer
DLP	Data Loss Prevention - technology to detect/prevent data exfiltration
IoT	Internet of Things - non-standard network-connected devices
MFA	Multi-Factor Authentication
NAIC	National Association of Insurance Commissioners
OFAC	Office of Foreign Assets Control
PCI DSS	Payment Card Industry Data Security Standard
PII	Personally Identifiable Information
SFTP	Secure File Transfer Protocol
SOC 2	Service Organization Control Type 2 audit
SSL/TLS	Secure Sockets Layer / Transport Layer Security
WAF	Web Application Firewall
ZPA	Zscaler Private Access
ZIA	Zscaler Internet Access
ZTNA	Zero Trust Network Access

Appendix B: Disclaimer

This document is the sole property of Meridian Insurance Group and contains confidential and proprietary information. It is intended exclusively for authorized personnel and must not be reproduced, distributed, or disclosed to third parties without prior written consent from the Chief Information Security Officer. This policy document is reviewed and updated according to the schedule defined in the Document Control section. Interim updates may be issued to address emerging threats, regulatory changes, or operational requirements. All employees and contractors are responsible for understanding and complying with this policy. Questions regarding interpretation or applicability should be directed to the Information Security Governance team.

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract, and may also result in civil or criminal penalties under applicable laws and regulations.